# Weekly Cyber Threat Intelligence Report

Reporting window: 6 - 12 October 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

**Prepared for: Jordan**

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

## Executive Summary

| 12 | 5 | 13 | 9 | 5 | 17 |
|---|---|---|---|---|---|
| Critical CVEs | High-sev vulns | Actively exploited | Notable breaches | PoCs / tools | IOCs to add |

This week's report covers **6 - 12 October 2026**. Dominant themes: **edge and enterprise platforms exploited at PoC speed** (Atlassian Data Center attacked within ~2 hours of a public PoC, SonicWall SMA1000 and AhsayCBS exploited, FortiBleed lockouts, GlobalProtect used by ransomware), **trust-infrastructure compromise** (ccTLD operators abused to mint Google certificates, tampered Ledger wallets from a SE Asian reseller, GhostAction and ChainDrop in CI/CD), and **AI agents as attack tooling** (ARTEX and Claude Code in Korean bank intrusions, PoeLLM hitting exposed AI servers). APAC was heavy: Integrity Tech/Flax Typhoon tooling seized, ransomware at Japan's IDCF Cloud, Osaka Metropolitan University and Advantest. Australia appears via the Wazza phishkit targeting AU banking and government.

## KEY CALLOUTS - SECTOR IMPACT

Who is affected this week

### OT / ICS & CRITICAL INFRASTRUCTURE

1 item

Integrity Tech's MicroScan/FishHub platforms were used by Flax Typhoon and other PRC APTs against critical infrastructure; five legacy edge CVEs went to KEV.

- HIGH Coalition seizes Integrity Tech (Flax Typhoon) MicroScan / FishHub hacking platforms; 5 CVEs added to KEV

### HEALTHCARE

5 items

Oracle Health tally nears 20M; iRhythm notifications; Doctreat (doctor-directory) WordPress takeover flaw.

- CRIT WordPress Doctreat Core CVE-2026-39773 (CVSS 10) unauthenticated privilege escalation
- HIGH Oracle Health (2025) breach tally climbs to nearly 20 million
- MEDI US offers USD 10M for Hafnium operator Zhang Yu (Shanghai Firetech)
- MEDI iRhythm notifies hundreds of thousands after summer cardiac-monitoring data breach
- MEDI Belarusian Cyber Partisans confirm months-long 2023 intrusion of Moscow Department of Health

### GOVERNMENT

11 items

Arizona courts (1.3M), Japan's IDCF Cloud outage across ~495 organisations, FortiBleed lockouts and Taiwan-focused AitM phishing.

- CRIT Citrix NetScaler CVE-2026-107406: critical SAML memory overflow RCE - freshly patched builds also affected
- CRIT FortiBleed: FBI and CISA warn ongoing attacks lock admins out of 86k+ FortiGate VPNs
- HIGH Arizona courts FARE breach exposes 1.3M+ people's data spanning three decades
- HIGH Coalition seizes Integrity Tech (Flax Typhoon) MicroScan / FishHub hacking platforms; 5 CVEs added to KEV
- HIGH Ransomware hits SoftBank's IDCF Cloud (Japan); ~495 organisations incl. local government and railways affected
- MEDI ClickFix: 100+ compromised Ukrainian sites deliver LunexStealer
- MEDI UAT-11985: AI-crafted event lures and QR-code posters feed Google sign-in AitM kit (Taiwan)
- MEDI Wazza phishkit targets banking, government and manufacturing in Australia, US and Europe

+ 3 more in the sections below

## MANUFACTURING

3 items

- MEDI Advantest (Japan) confirms personal data stolen in February ransomware attack
- MEDI Wazza phishkit targets banking, government and manufacturing in Australia, US and Europe
- INFO Cybercrime prosecutions: Empire Market co-founder 40 years; Uranium Finance thief convicted; insider extortionist jailed

## FINANCIAL

6 items

AI-agent intrusions at seven Korean banks, USD 86M+ drained via tampered Ledger devices, wallet-stealing extensions and DarkSword P7.

- CRIT FortiBleed: FBI and CISA warn ongoing attacks lock admins out of 86k+ FortiGate VPNs
- HIGH Ledger confirms hardware implant in devices sold by SE Asian reseller CryptoBilis; ~USD 86-93M drained
- HIGH P7 DarkSword iOS exploit kit adds crypto-wallet and keychain theft
- HIGH South Korean bank intrusions used ARTEX AI pentest suite and Claude Code agents; 7 institutions, 68k+ people
- MEDI 16 malicious Firefox add-ons impersonate Rabby / OKX to steal seed phrases
- MEDI Wazza phishkit targets banking, government and manufacturing in Australia, US and Europe

## ENERGY / UTILITIES

1 item

- MEDI Southern Company: Georgia Power / Alabama Power customer portal breach hits ~400,000 accounts

## TRANSPORT / AVIATION

1 item

- HIGH Ransomware hits SoftBank's IDCF Cloud (Japan); ~495 organisations incl. local government and railways affected

## TELECOM

3 items

- CRIT Cisco patches 12 criticals incl. five NX-OS flaws giving root code execution on Nexus switches
- CRIT FortiBleed: FBI and CISA warn ongoing attacks lock admins out of 86k+ FortiGate VPNs
- HIGH Coalition seizes Integrity Tech (Flax Typhoon) MicroScan / FishHub hacking platforms; 5 CVEs added to KEV

## DEFENSE / AEROSPACE

1 item

- HIGH ShinyHunters crackdown: multiple FBI arrests; ransomware-negotiation firm founder arrested

## EDUCATION

3 items

- MEDI Osaka Metropolitan University suspected ransomware: ~500 servers down, classes cancelled
- MEDI UAT-11985: AI-crafted event lures and QR-code posters feed Google sign-in AitM kit (Taiwan)
- MEDI US offers USD 10M for Hafnium operator Zhang Yu (Shanghai Firetech)

RETAIL / CONSUMER 6 items

- HIGH ASOS breach: social-engineered employee account used to send rogue 'HACKED' push alerts and access customer data
- HIGH Ledger confirms hardware implant in devices sold by SE Asian reseller CryptoBilis; ~USD 86-93M drained
- HIGH Midnight Mimosa: malware pre-installed in budget Android firmware across 150+ countries
- HIGH Ninja Forms and WPC Product Bundles stored XSS exploited to backdoor WordPress sites
- HIGH ShinyHunters crackdown: multiple FBI arrests; ransomware-negotiation firm founder arrested
- MEDI 16 malicious Firefox add-ons impersonate Rabby / OKX to steal seed phrases

TECHNOLOGY / SaaS / DEV 13 items

Atlassian, AhsayCBS, Next.js PoC and CI/CD worms (GhostAction, ChainDrop) put developer and backup infrastructure in the crosshairs.

- CRIT AhsayCBS CVE-2026-105134 / -105133 auth bypass + command injection exploited; 10.3.4 still affected
- CRIT Atlassian CVE-2026-21589: Jira/Confluence/Bitbucket Data Center unauth file access exploited within hours of PoC
- CRIT Cisco patches 12 criticals incl. five NX-OS flaws giving root code execution on Nexus switches
- CRIT Next.js ImageResponse CVE-2026-94545 RCE - public PoC (EQSTLab)
- HIGH ChainDrop / Shai-Hulud worm compromises tensorlake npm SDK (0.5.144)
- HIGH FakeGit returns with 17,610 malicious GitHub repos pushing SmartLoader / StealC
- HIGH GhostAction returns: credential-stealing GitHub Actions workflows pushed to tens of thousands of repos
- HIGH PoeLLM botnet compromises 3,400+ exposed LiteLLM / Ollama / Gitea servers for mining

+ 5 more in the sections below

CROSS-SECTOR / ENTERPRISE IT 19 items

Edge appliances (SonicWall, Citrix, GlobalProtect), Chrome 155 and rogue Google certificates affect every organisation.

- CRIT Atlassian CVE-2026-21589: Jira/Confluence/Bitbucket Data Center unauth file access exploited within hours of PoC
- CRIT Chrome 155 fixes 247 flaws incl. four critical use-after-frees
- CRIT Citrix NetScaler CVE-2026-107406: critical SAML memory overflow RCE - freshly patched builds also affected
- CRIT Palo Alto GlobalProtect CVE-2026-0257 auth bypass used by ransomware (Qilin) for VPN access
- CRIT Pwn2Own Ireland: 98 zero-days, USD 1.26M; Pixel 10 and Galaxy S26 each exploited three times
- CRIT SonicWall SMA1000 CVE-2026-102255 (CVSS 10) pre-auth SSRF now exploited
- CRIT ccTLD operators for .GH, .AS and .SL breached; rogue HTTPS certs issued for Google domains
- HIGH LibreOffice / OpenOffice flaws let malicious spreadsheets run code without macro warnings

+ 11 more in the sections below

## AUSTRALIA - SPECIFIC

Local orgs & data

### Wazza phishkit targets banking, government and manufacturing in Australia, US and Europe

MEDIUM VERIFIED Phishing AU

ANY.RUN-identified phishing kit with built-in visitor filtering (anti-bot / anti-sandbox), session management and traffic controls so scanners see benign pages while real victims get credential-harvest flows. Australian banking, manufacturing and government organisations are named targets. Hunt with residential-egress sandboxing and real browser fingerprints; pivot on kit panel paths and TLS certificate reuse.

Refs: thehackernews.com · scworld.com · secnews.gr

## APAC - SPECIFIC

Regional incidents & actors

### Coalition seizes Integrity Tech (Flax Typhoon) MicroScan / FishHub hacking platforms; 5 CVEs added to KEV

HIGH VERIFIED APT China KEV

FBI seized seven domains running the MicroScan scanning and FishHub intrusion tools operated by Beijing-based Integrity Tech, used by Flax Typhoon and other PRC APTs against US and allied critical infrastructure. NSA, FBI and partners issued joint defensive guidance; CISA added five old edge-device CVEs (incl. CVE-2015-3306 ProFTPD, CVE-2016-3081 Struts, CVE-2021-3199, CVE-2023-22894) to KEV with an 11 October deadline.

**PoC: Active exploitation in the wild**

Refs: bleepingcomputer.com · therecord.media · securityweek.com

### Ledger confirms hardware implant in devices sold by SE Asian reseller CryptoBilis; ~USD 86-93M drained

HIGH VERIFIED SupplyChain Crypto SEA

Owners of Ledger wallets bought from official reseller CryptoBilis (Indonesia, Malaysia, Philippines) lost funds; onchain estimates run from USD 86M to USD 92.9M across ~311 wallets. Ledger paused the reseller and confirmed an unauthorised hardware implant in at least one device. Claims of a DPRK front behind the reseller remain unverified. Hardware supply-chain tampering, not a firmware flaw: buy direct from the vendor.

Refs: theblock.co · protos.com · decrypt.co

### Ransomware hits SoftBank's IDCF Cloud (Japan); ~495 organisations incl. local government and railways affected

HIGH VERIFIED Ransomware Japan Cloud

A data-centre cluster of IDC Frontier's IDCF Cloud serving eastern Japan was hit by ransomware, taking prefectural/municipal websites, railway, police and food-supplier services offline. No group has claimed the attack yet - watch leak sites. Single-provider concentration risk for public-sector hosting.

Refs: bleepingcomputer.com · cybernews.com · nippon.com

### South Korean bank intrusions used ARTEX AI pentest suite and Claude Code agents; 7 institutions, 68k+ people

HIGH VERIFIED AI Korea DataTheft

Korean officials say AI agents were used to breach seven financial institutions, exposing data on at least 68,000 people. CrowdStrike found the Chinese open-source agentic pentest suite ARTEX (DeepSeek backend via LLM reseller xcai[.]pro, plus GLM and Grok) and Claude Code session artefacts on attacker infrastructure. Offensive AI agents are now operational tooling for data theft.

Refs: therecord.media · bleepingcomputer.com · thehackernews.com

### Advantest (Japan) confirms personal data stolen in February ransomware attack

MEDIUM VERIFIED Ransomware Japan

The chip-testing giant is notifying individuals months after the attack. Semiconductor supply chain remains a priority ransomware target.

Refs: bleepingcomputer.com · securityweek.com · techradar.com

### JPCERT/CC warns of surge in Japanese web data leaks via mobile-API abuse and Metabase exploitation

MEDIUM VERIFIED Japan API Metabase

JPCERT/CC alert (8 Oct): personal-data leaks tied to abuse of mobile app backend APIs (unauthenticated listing endpoints, IDOR) and known flaws incl. Metabase (CVE-2023-38646 class). Audit mobile APIs and exposed Metabase instances.

Refs: thehackernews.com · internet.watch.impress.co.jp · innovatopia.jp

### Osaka Metropolitan University suspected ransomware: ~500 servers down, classes cancelled

MEDIUM VERIFIED Ransomware Japan

Networks, email and administrative systems were disabled and classes cancelled; data leakage is suspected. No group attributed.

Refs: therecord.media · nippon.com · newsonjapan.com

### Qilin ransomware suspect arrested in Japan, extradited to Germany

MEDIUM VERIFIED Ransomware LawEnf Japan

Alleged core Qilin member detained in Japan in May and extradited to Germany on hacking charges - part of a wave of ransomware/extortion arrests this month (ShinyHunters, MonsterCloud, CYPFER exec).

Refs: securityweek.com · therecord.media · bleepingcomputer.com

### UAT-11985: AI-crafted event lures and QR-code posters feed Google sign-in AitM kit (Taiwan)

MEDIUM VERIFIED APT Taiwan AitM

Cisco Talos tracks spear-phishing with AI-assisted event-themed lures and malicious QR codes printed on event posters, leading to a real-time adversary-in-the-middle kit impersonating Google sign-in that relays MFA. Push phishing-resistant MFA (FIDO2) for targeted staff.

Refs: blog.talosintelligence.com · blog.gridinsoft.com · ithome.com.tw

### US offers USD 10M for Hafnium operator Zhang Yu (Shanghai Firetech)

MEDIUM VERIFIED APT China LawEnf

Rewards for Justice offer for the MSS-tasked director of Shanghai Firetech, indicted for 2020-21 intrusions incl. theft of COVID-19 research; co-accused Xu Zewei was extradited from Italy in April. FBI ties the Hafnium campaign to 60,000+ US entities targeted.

Refs: therecord.media · securityweek.com · thehackernews.com

### Claim: 7.5GB of India MEA / NIC confidential emails offered for sale

MEDIUM UNVERIFIED Claim India

An underground-forum actor advertises ~7.5GB of emails from India's Ministry of External Affairs and National Informatics Centre. No official confirmation or independent sample analysis found; treat as a claim.

Refs: x.com/DailyDarkWeb

## GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

Patch now

### AhsayCBS CVE-2026-105134 / -105133 auth bypass + command injection exploited; 10.3.4 still affected

CRITICAL VERIFIED CVE Backup 0day

Chained auth bypass (checkSysPwd) and OS command injection in the Replication Receiver give RCE on AhsayCBS backup servers. Huntress saw exploitation from 7 Oct dropping web shells and an XMRig miner as edge.exe with WinRing0x64.sys; the 'fixed' 10.3.4 build is reported still vulnerable. Restrict management/Replication Receiver to trusted IPs.

**PoC: Active exploitation in the wild**

Refs: huntress.com · bleepingcomputer.com · thehackernews.com

### Atlassian CVE-2026-21589: Jira/Confluence/Bitbucket Data Center unauth file access exploited within hours of PoC

CRITICAL VERIFIED CVE Atlassian PoC

Unauthenticated arbitrary file access in web-app root directories across 8 self-hosted Data Center products. A public PoC landed and exploitation began within ~2 hours; SANS ISC observed mass scanning. Patch immediately and review exposed web roots and access logs.

**PoC: Public PoC + exploited in the wild - bleepingcomputer.com**

Refs: bleepingcomputer.com · securityweek.com · isc.sans.edu

### Chrome 155 fixes 247 flaws incl. four critical use-after-frees

CRITICAL VERIFIED CVE Chrome Browser

Critical UAFs CVE-2026-106382, -106197, -106358, -106347 (Chromecast, Browser, Navigation, Track). No in-the-wild exploitation reported. Fixed in 155.0.8059.39/.40 (Win/macOS) and .39 (Linux).

Refs: securityweek.com · esecurityplanet.com · dailysecurityreview.com

### Cisco patches 12 criticals incl. five NX-OS flaws giving root code execution on Nexus switches

CRITICAL VERIFIED CVE Cisco Network

Five critical NX-OS advisories allow arbitrary code execution as root on Nexus switches; SecurityWeek counts 12 critical fixes in the drop (access, info leak, privesc, DoS, RCE). No exploitation reported. Pull CVE IDs from Cisco PSIRT and prioritise data-centre fabric.

Refs: bleepingcomputer.com · securityweek.com · socradar.io

### Citrix NetScaler CVE-2026-107406: critical SAML memory overflow RCE - freshly patched builds also affected

CRITICAL VERIFIED CVE Citrix Edge

Memory overflow reachable when NetScaler ADC/Gateway is a SAML IdP or SP; RCE or DoS. Citrix issued immediate guidance on 8 Oct. Not yet exploited, but three other NetScaler bugs are, and the builds admins rushed to last week are vulnerable. Upgrade to the new recommended builds.

Refs: thehackernews.com · securityweek.com · cyber.gc.ca

### FortiBleed: FBI and CISA warn ongoing attacks lock admins out of 86k+ FortiGate VPNs

CRITICAL VERIFIED Fortinet Credentials Edge

The FortiBleed leak of Fortinet VPN credentials (73k-86,644 devices) is being actively abused: FBI says attackers are changing admin credentials and locking victims out of FortiGate appliances. Rotate all FortiGate admin/VPN credentials, enforce MFA, restrict management interfaces and review config changes.

**PoC: Active exploitation in the wild**

Refs: bleepingcomputer.com · thehackernews.com · securityweek.com

### Palo Alto GlobalProtect CVE-2026-0257 auth bypass used by ransomware (Qilin) for VPN access

CRITICAL VERIFIED CVE PaloAlto Ransomware

Ransomware affiliates are using the GlobalProtect authentication bypass to obtain stealthy VPN access, followed by encryption or double extortion. Confirm fixed PAN-OS versions and review GlobalProtect logins without matching IdP/MFA events.

**PoC: Active exploitation in the wild**

Refs: securityaffairs.com · beazley.security · sentinelone.com

### Pwn2Own Ireland: 98 zero-days, USD 1.26M; Pixel 10 and Galaxy S26 each exploited three times

CRITICAL VERIFIED 0day Mobile Pwn2Own

Pixel 10 remotely exploited 3x (USD 560k combined, Ikotas Labs Master of Pwn); Galaxy S26 hit 3 more times; printers and smart-home devices also fell. Vendors have 90 days before ZDI disclosure - expect a wave of Android/Samsung and IoT patches.

Refs: bleepingcomputer.com · securityweek.com · cyberinsider.com

### SonicWall SMA1000 CVE-2026-102255 (CVSS 10) pre-auth SSRF now exploited

CRITICAL VERIFIED CVE SonicWall Edge

Unauthenticated SSRF in the SMA1000 Appliance WorkPlace interface (6210, 7210, 8200v); SMA100 and firewall SSL-VPN not affected. Hotfixes shipped 6 Oct (SNWLID-2026-0017), no workaround; exploitation confirmed 9 Oct. ~400 SMA1000 appliances exposed per Shadowserver. Third max-severity SMA1000 SSRF.

**PoC: Active exploitation in the wild**

Refs: bleepingcomputer.com · cyber.gc.ca · scworld.com

### WordPress Doctreat Core CVE-2026-39773 (CVSS 10) unauthenticated privilege escalation

CRITICAL VERIFIED CVE WordPress

Doctreat Core <= 1.7.0 (doctor-directory theme companion) allows unauthenticated privilege escalation to full site takeover. Update or disable; check for new admin accounts.

Refs: patchstack.com · thehackerwire.com · secalerts.co

### Fanvil X7A CVE-2025-70518 unauthenticated command injection (CVSS 10)

CRITICAL UNVERIFIED CVE VoIP IoT

Firmware 2.6.0.1182: OS command injection via the management portal's diagnostic ping tool, no auth. Only CVE-record aggregators so far; confirm vendor fix and keep IP-phone management off untrusted networks.

Refs: app.opencve.io · thehackerwire.com

### Microsoft discloses five critical cloud-service CVEs incl. Partner Center CVE-2026-96207 (CVSS 10)

CRITICAL UNVERIFIED CVE Microsoft Cloud

MSRC published CVE-2026-96207 (Partner Center improper certificate validation, unauth privesc, CVSS 10), CVE-2026-94510 (Bookings IDOR, 9.9), CVE-2026-77900 (App Service for Linux, 9.8) and two more. Service-side fixes, no customer action generally required; review tenant audit logs. Limited independent coverage so far.

Refs: thehackerwire.com · msrc.microsoft.com

## GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

### LibreOffice / OpenOffice flaws let malicious spreadsheets run code without macro warnings

HIGH VERIFIED Office CodeExec

Spreadsheets trigger code execution silently when Java support is enabled. LibreOffice has patched; Apache OpenOffice status lags. Update and disable Java integration where unused.

Refs: thehackernews.com · esecurityplanet.com · sqmagazine.co.uk

### Ninja Forms and WPC Product Bundles stored XSS exploited to backdoor WordPress sites

HIGH VERIFIED WordPress XSS

Stored XSS in the plugins is being used to plant backdoors and create rogue administrator accounts. Update both plugins and audit for unknown admins and injected scripts.

**PoC: Active exploitation in the wild**

Refs: bleepingcomputer.com · privacysavvy.com · dailysecurityreview.com

### Telegram Desktop CVE-2026-107181 one-click file / session theft (CVSS 8.6) - public PoC

HIGH VERIFIED CVE Telegram PoC

Before 7.2.9, a crafted link makes the client send local files and session data after one click, enabling account takeover (researcher BeakSec). Update to 7.2.9+ and set a local passcode.

**PoC: Public - PoC write-up (BeakSec) - securityonline.info**

Refs: cybernews.com · securityonline.info · ubuntu.com

### AnyDesk Linux 8.0.2 pre-auth heap overflow to root - working exploit published (AnyPwn)

HIGH UNVERIFIED RCE AnyDesk PoC

Unchecked 32-bit length math in the session-protocol stream handler; exploit posted to GitHub 8 Oct (Rick de Jager / V12), direct TCP 7070 only, probabilistic and build-specific. Silently fixed in 8.0.3 (June); no CVE yet. Windows/macOS unaffected. Upgrade and block inbound 7070.

**PoC: Public - exploit on GitHub (AnyPwn) - thehackernews.com**

Refs: thehackernews.com

### CCCS advisories: SmarterMail (pre-9777), MongoDB and HPE iMC updates

HIGH UNVERIFIED Advisory CCCS

Canadian Centre for Cyber Security flagged SmarterTools SmarterMail builds before 9777 (prior KEV history), MongoDB and HPE Intelligent Management Center fixes. No CVSS published in the advisories; patch SmarterMail promptly.

Refs: cyber.gc.ca

## GLOBAL - SOFTWARE SUPPLY CHAIN

Registries, CI/CD & PKI

### ccTLD operators for .GH, .AS and .SL breached; rogue HTTPS certs issued for Google domains

CRITICAL VERIFIED DNS PKI SupplyChain

Attackers compromised third-party operators of three country-code TLDs, altered authoritative DNS, passed domain validation and obtained unauthorised certificates for Google and other major brands. Google blocked the certs in Chrome via CRLSets; non-Chrome clients may still trust them. Monitor CT logs for your domains and consider CAA records.

Refs: bleepingcomputer.com · thehackernews.com · itnews.com.au

### ChainDrop / Shai-Hulud worm compromises tensorlake npm SDK (0.5.144)

HIGH VERIFIED npm Worm

The self-propagating ChainDrop variant (1,300+ package versions since the keyv maintainer compromise) hit tensorlake@0.5.144 with credential harvesting, secret exfil and persistence. Run npm ls tensorlake, pin away from 0.5.144 and rotate tokens on affected hosts/CI.

Refs: thehackernews.com · bleepingcomputer.com · isc.sans.edu

### GhostAction returns: credential-stealing GitHub Actions workflows pushed to tens of thousands of repos

HIGH VERIFIED GitHub CI/CD Secrets

Compromised maintainer accounts (likely PATs from infostealer logs) commit security-audit.yml / github_actions_security.yml workflows that dump secrets and scan history for 13 credential patterns, exfiltrating over plain HTTP to 193.32.204[.]199. Socket counts 500+ accounts since 7 Oct. Search orgs for the files and IP, rotate CI secrets.

Refs: thehackernews.com · stepsecurity.io · gbhackers.com

## GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

### Next.js ImageResponse CVE-2026-94545 RCE - public PoC (EQSTLab)

CRITICAL VERIFIED PoC Next.js

Crafted SVG passed to ImageResponse (OG-image routes) yields server code execution. Public PoC repo EQSTLab/CVE-2026-94545 released; treat as weaponised. Upgrade Next.js and audit OG routes that take query parameters.

**PoC: Public - GitHub EQSTLab/CVE-2026-94545 - github.com/EQSTLab**

Refs: thehackernews.com · wiz.io · netlify.com

### AnyPwn - AnyDesk Linux pre-auth root exploit released on GitHub

HIGH UNVERIFIED PoC AnyDesk

Working exploit for AnyDesk Linux 8.0.2 (see Other Notable Vulnerabilities). Direct TCP 7070, build-specific offsets. Defenders: upgrade to 8.0.3+ and alert on inbound 7070.

**PoC: Public - exploit code on GitHub - thehackernews.com**

Refs: thehackernews.com

### Technique: gateway/backend parser differential bypasses JWT auth via .json suffix + %23 (USD 10K bounty)

MEDIUM UNVERIFIED Technique BugBounty

Gateway skipped auth for paths ending .json; payload /api/employee/12345%23.json passed the gateway while the backend decoded and truncated at '#', returning the record. Test API gateways for static-suffix auth exemptions and decode mismatches.

Refs: x.com/infinitelogins

### GoSearch - Go username OSINT across 300+ sites

INFO UNVERIFIED Tool OSINT

Username reconnaissance tool (ibnaleem/gosearch) to map a handle's footprint; useful for phishing-exposure and executive-protection reviews.

Refs: github.com/ibnaleem

### REA (Reverse Engineer Anything): AI coding agents drive Ghidra / IDA Pro

INFO UNVERIFIED Tool RE AI

Open-source tool connecting Claude Code / Cursor to Ghidra and IDA so an agent can disassemble and reconstruct closed-source features; #1 trending GitHub repo on 9 Oct. Useful for binary triage - run in an isolated VM, no secrets in env.

Refs: raw.githubusercontent.com · byteiota.com

## GLOBAL - MALWARE & CAMPAIGNS

### FakeGit returns with 17,610 malicious GitHub repos pushing SmartLoader / StealC

HIGH VERIFIED Stealer GitHub

Fake tools, cheats, cracks and 'PoCs' deliver the LuaJIT SmartLoader, which drops StealC. Red flags: release ZIPs with lua51.dll / luajit.exe and obfuscated .txt. Never run fresh-CVE PoC repos outside a disposable VM.

Refs: bleepingcomputer.com · scworld.com · it-connect.tech

### Midnight Mimosa: malware pre-installed in budget Android firmware across 150+ countries

HIGH VERIFIED Android Firmware Proxy

Bitdefender found malware baked into firmware of low-cost (often MediaTek clone) Android phones: silent app installs, ad fraud and residential-proxy resale of victim devices. BadBox/Triada lineage. Keep unmanaged budget devices off corporate networks.

Refs: bleepingcomputer.com · securityweek.com · bitdefender.com

### P7 DarkSword iOS exploit kit adds crypto-wallet and keychain theft

HIGH VERIFIED iOS Exploit kit Wallet

iVerify: leaked DarkSword kit, operated by a suspected Chinese-speaking exploitation-as-a-service actor, now steals keychain, wallets (imToken and 25+ others), Notes and Photos with 15s C2 polling. Targets iOS 18.4-18.7 (CVE-2025-24201, CVE-2025-31200); attempts on iOS 26 failed. Keep iPhones current; Lockdown Mode for high-risk users.

**PoC: Active exploitation in the wild**

Refs: thehackernews.com · 9to5mac.com · ibtimes.co.uk

### PoeLLM botnet compromises 3,400+ exposed LiteLLM / Ollama / Gitea servers for mining

HIGH VERIFIED AI Botnet Cryptomining

Lumen Black Lotus Labs: active since April, exploits LiteLLM CVE-2026-42271 (chains with CVE-2026-48710 for unauth RCE), drops an ELF disguised as libgcrypt with XMRig, scans ports 3000/4000, and hides C2 IPs in a poem in a GitHub-hosted dash.css. Do not expose AI gateways to the internet.

**PoC: Active exploitation in the wild**

Refs: bleepingcomputer.com · thehackernews.com · helpnetsecurity.com

### 16 malicious Firefox add-ons impersonate Rabby / OKX to steal seed phrases

MEDIUM VERIFIED Extensions Crypto

Add-ons posing as wallet portals and utilities intercept recovery phrases and private keys during wallet import; Mozilla removed them. Allow-list browser extensions in managed fleets.

Refs: thehackernews.com · cybernews.com · gbhackers.com

### ClickFix: 100+ compromised Ukrainian sites deliver LunexStealer

MEDIUM VERIFIED ClickFix Stealer Ukraine

Fake Cloudflare/verification pages trick users into pasting commands that install LunexStealer (CERT-UA). Restrict Win+R / PowerShell for standard users and block clipboard-to-run lures.

Refs: therecord.media · thehackernews.com · hackread.com

### MonsterCloud CEO charged: secretly paid ransoms, sold victims 'proprietary' decryption at ~USD 11M markup

MEDIUM VERIFIED Ransomware Fraud LawEnf

Zohar Pinhasi allegedly ran a ~USD 19M scheme buying decryptors from extortionists while billing victims for fake recovery tools - potentially exposing victims to sanctions risk. Vet IR/recovery vendors' payment practices.

Refs: bleepingcomputer.com · securityweek.com · cyberscoop.com

### ClickFix 'Adception': Google Ads and Bing redirects push fake Claude Code installers

MEDIUM UNVERIFIED ClickFix macOS AI lure

Search ads for 'claude mac' route via bing.com/ck/a to compromised WordPress sites showing the real install one-liner; the copy button swaps in a base64 command piping a payload from lake-90[.]com into zsh. Hunt curl | zsh with base64 decode on macOS.

Refs: bleepingcomputer.com · cybersecuritynews.com

### DFIR Report: ClickFix intrusion drops KeyUpdateAgent.exe laterally (IOCs)

MEDIUM UNVERIFIED ClickFix IOC

ClickFix access led to lateral drops of C:\Windows\security\KeyUpdateAgent.exe beaconing to 67[.]207[.]81[.]22:443 (sunyotech[.]com). Hunt executables written to C:\Windows\security\.

Refs: x.com/TheDFIRReport

### UAC-0099 hijacks Notepad++ plugin to deliver ASHVEIN RAT to Ukrainian government

MEDIUM UNVERIFIED APT Ukraine

Trusted editor plugin abused for execution and persistence under a benign process. Monitor Notepad++ plugin directories for unsigned DLLs.

Refs: thehackernews.com · securityaffairs.com

## GLOBAL - NOTABLE BREACHES

### ASOS breach: social-engineered employee account used to send rogue 'HACKED' push alerts and access customer data

HIGH VERIFIED Breach Retail SocEng

ASOS confirmed customer data theft (claimed from Snowflake) after attackers tricked an employee, gained access and pushed extortion notifications through the app. Lock down push-notification consoles behind phishing-resistant MFA.

Refs: bleepingcomputer.com · therecord.media · techcrunch.com

### Arizona courts FARE breach exposes 1.3M+ people's data spanning three decades

HIGH VERIFIED Breach Gov

Attackers stole personal data (incl. SSNs per some reports) from the FARE program used to collect traffic and criminal-case debts. Expect follow-on phishing impersonating courts.

Refs: securityweek.com · therecord.media · news.bloomberglaw.com

### Oracle Health (2025) breach tally climbs to nearly 20 million

HIGH VERIFIED Breach Health

Texas AG figures put the Oracle Health/Cerner breach at ~20M people, far above earlier filings, as downstream hospital customers keep notifying.

Refs: securityweek.com · techzine.eu · esecurityplanet.com

### ShinyHunters crackdown: multiple FBI arrests; ransomware-negotiation firm founder arrested

HIGH VERIFIED Extortion LawEnf

FBI arrested further suspected ShinyHunters members (one after an agency breach), Krebs reports the group extorted a Boeing spin-off before arrests, and CYPFER exec Dubrovsky was arrested in the probe. Kodak (2.2M records) remains among confirmed victims.

Refs: bleepingcomputer.com · krebsonsecurity.com · thehackernews.com

### Southern Company: Georgia Power / Alabama Power customer portal breach hits ~400,000 accounts

MEDIUM VERIFIED Breach Utility

Utility account information accessed (IT-side, not OT). Expect fake bill / shut-off phishing against customers.

Refs: securityweek.com · wsbtv.com · fox10tv.com

### iRhythm notifies hundreds of thousands after summer cardiac-monitoring data breach

MEDIUM VERIFIED Breach Health

The wearable cardiac monitor maker completed its forensic review of the June incident (third-party involvement reported) and began notifying affected individuals; PHI accessed.

Refs: therecord.media · finviz.com · compliancehub.wiki

### Belarusian Cyber Partisans confirm months-long 2023 intrusion of Moscow Department of Health

MEDIUM UNVERIFIED Hacktivist Russia

Hacktivists confirmed Russian researchers' findings; access method not disclosed.

Refs: therecord.media

### Claim: The Gentlemen ransomware lists Deloitte (UK) on leak site

MEDIUM UNVERIFIED Ransomware Claim

Leak-site listing only; no data sample or company confirmation at time of writing. Watch for professional-services third-party exposure if confirmed.

Refs: x.com/DarkWebInformer

### Cybercrime prosecutions: Empire Market co-founder 40 years; Uranium Finance thief convicted; insider extortionist jailed

INFO UNVERIFIED LawEnf Insider

Empire Market (~USD 430M trades) co-creator sentenced to 40 years; Uranium Finance USD 53M hacker found guilty; an industrial-firm engineer who deleted admins and demanded 20 BTC was imprisoned; YMCO money-mule leader pleaded guilty; alleged ATM-malware fugitive appeared in Nebraska court. Lesson: revoke privileged access at notice and alert on mass password resets.

Refs: bleepingcomputer.com · securityweek.com · therecord.media

## INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

| Indicator | Type | Context | Reference |
|---|---|---|---|
| **CVE-2026-21589** | CVE | Atlassian Data Center unauth file access, exploited after public PoC | bleepingcomputer.com |
| **CVE-2026-102255** | CVE | SonicWall SMA1000 WorkPlace SSRF (CVSS 10), exploited | bleepingcomputer.com |
| **CVE-2026-105134 / CVE-2026-105133** | CVE | AhsayCBS auth bypass + command injection, exploited, 10.3.4 still affected | huntress.com |

| Indicator | Type | Context | Reference |
|---|---|---|---|
| `CVE-2026-0257` | CVE | GlobalProtect auth bypass used by Qilin affiliates for VPN access | securityaffairs.com |
| `CVE-2026-107406` | CVE | Citrix NetScaler SAML memory overflow RCE | securityweek.com |
| `CVE-2026-94545 / CVE-2026-107181` | CVE | Next.js ImageResponse RCE and Telegram Desktop file theft - public PoCs | securityonline.info |
| `CVE-2026-42271 / CVE-2026-48710` | CVE | LiteLLM chain exploited by PoeLLM botnet (scans TCP 3000/4000) | bleepingcomputer.com |
| `193.32.204[.]199` | IP | GhostAction GitHub Actions secret exfil (HTTP); files security-audit.yml, github_actions_security.yml | thehackernews.com |
| `tensorlake@0.5.144` | Package | npm package trojanised by ChainDrop / Shai-Hulud | thehackernews.com |
| `xcai[.]pro` | Domain | LLM API reseller used by ARTEX operator in Korean bank intrusions | bleepingcomputer.com |
| `claude-desk-code[.]com, lake-90[.]com` | Domain | Claude-themed ClickFix (Adception) lure and payload host | bleepingcomputer.com |
| `ecomtrack[.]io, chainmate[.]top, mertio[.]cc, 66ds[.]lol` | Domain | P7 DarkSword iOS exploit-kit infrastructure | thehackernews.com |
| `43.134.165[.]205, 166.88.95[.]90, 47.102.192[.]23, 156.239.230[.]120, 23.148.212[.]237` | IP | P7 DarkSword C2 / hosting | thehackernews.com |
| `67[.]207[.]81[.]22:443 / sunyotech[.]com` | IP/Domain | ClickFix intrusion C2 (KeyUpdateAgent.exe) | x.com/TheDFIRReport |
| `ec9ada555d6dffa2fed08e86e26e29e7c6d15d90e0323cdf44e06e75461a04bf` | SHA256 | KeyUpdateAgent.exe dropped in C:\Windows\security\ | x.com/TheDFIRReport |
| `edge.exe, Taskgmr.ps1, WinRing0x64.sys in %TEMP%` | File | AhsayCBS post-exploitation XMRig miner and driver | huntress.com |
| `Inbound TCP/7070` | Network | AnyDesk Linux direct-connect port targeted by AnyPwn exploit | thehackernews.com |

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

## TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

### Exploitation now starts at PoC publication, not patch day

**Why it matters:** Atlassian CVE-2026-21589 was attacked within ~2 hours of a public PoC; SonicWall SMA1000 and AhsayCBS went from advisory to exploitation in days, AhsayCBS before a working fix existed; Next.js, Telegram and AnyDesk exploits all went public.

**Watch for:** PoC repos for this week's CVEs (Cisco NX-OS, Citrix CVE-2026-107406, Chrome 155), KEV additions, and FakeGit-style trojanised 'PoCs'. Pre-stage emergency patch paths for internet-facing products.

HIGH

### Trust infrastructure is the target: DNS/PKI, hardware resellers and CI/CD

**Why it matters:** Attackers hijacked three ccTLD operators to mint Google certificates, a SE Asian reseller shipped implanted Ledger wallets, and GhostAction/ChainDrop abused maintainer credentials to poison workflows and npm.

**Watch for:** Unexpected certificates in CT logs, CAA gaps, new .github/workflows files, token use from new IPs, and devices bought through non-direct channels.

HIGH

### AI agents move from research to operational intrusion tooling

**Why it matters:** ARTEX plus Claude Code artefacts in seven Korean bank breaches, PoeLLM mass-exploiting exposed LiteLLM/Ollama, malware embedding prompt injection to fool LLM triage (Talos), and Google pausing OSS bounties over AI-generated noise.

**Watch for:** High-tempo scanning with LLM-generated payloads, exposed AI gateways/MCP servers, and prompt-injection strings in samples. Never let model verdicts auto-close detections.

MED

### APAC cloud and education ransomware, with concentration risk

**Why it matters:** IDCF Cloud's outage cascaded to ~495 Japanese organisations; Osaka Metropolitan University and Advantest also disclosed attacks, while a Qilin suspect was arrested in Japan.

**Watch for:** Leak-site claims for IDCF and Osaka, further Japanese public-sector impact, and dependency mapping for single-provider hosting in the region.

## PRIORITY ACTIONS THIS WEEK

| Area | Action |
|---|---|
| Patch now | Atlassian Data Center (CVE-2026-21589); SonicWall SMA1000 hotfix (CVE-2026-102255); Citrix NetScaler new builds (CVE-2026-107406); PAN-OS GlobalProtect (CVE-2026-0257); Cisco NX-OS criticals; Chrome 155; Telegram Desktop 7.2.9; AnyDesk Linux 8.0.3+; LibreOffice; Ninja Forms, WPC Product Bundles and Doctreat Core; Next.js (CVE-2026-94545). |
| Block IOCs | Import the IOC table into firewall/EDR/SIEM: block 193.32.204.199, the DarkSword and ClickFix domains/IPs and xcai.pro; alert on the listed CVEs, tensorlake@0.5.144, the KeyUpdateAgent hash, edge.exe/WinRing0x64.sys in %TEMP% and inbound TCP 7070. Re-fang indicators before import. |
| Assume compromise | Treat exposed AhsayCBS, SMA1000 and Atlassian DC as potentially compromised: hunt web shells and miners. Rotate all FortiGate admin/VPN credentials (FortiBleed), CI/CD secrets in repos with the GhostAction workflows, and tokens on hosts that installed tensorlake. |
| Harden | Restrict AI gateways (LiteLLM/Ollama) and backup consoles to VPN; add CAA records and CT-log monitoring; enforce FIDO2 for admin, push-notification and source-control accounts; allow-list browser extensions; buy hardware wallets direct from vendors. |